

第 8 章

iptables 与 firewalld 防火墙

本章讲解了如下内容：

- 防火墙管理工具；
- iptables；
- firewalld；
- 服务的访问控制列表。

保障数据的安全性是继保障数据的可用性之后最为重要的一项工作。防火墙作为公网与内网之间的保护屏障，在保障数据的安全性方面起着至关重要的作用。考虑到大家还不了解 RHEL 7 中新增的 firewalld 防火墙与先前版本中 iptables 防火墙之间的区别，刘遄老师决定先带领读者从理论层面和实际层面正确地认识在这两款防火墙之间的关系。

本章将分别使用 iptables、firewall-cmd、firewall-config 和 TCP Wrappers 等防火墙策略配置服务来完成数十个根据真实工作需求而设计的防火墙策略配置实验。在学习完这些实验之后，各位读者不仅可以熟练地过滤请求的流量，还可以基于服务程序的名称对流量进行允许和拒绝操作，确保 Linux 系统的安全性万无一失。

8.1 防火墙管理工具

众所周知，相较于企业内网，外部的公网环境更加恶劣，罪恶丛生。在公网与企业内网之间充当保护屏障的防火墙（见图 8-1）虽然有软件或硬件之分，但主要功能都是依据策略对穿越防火墙自身的流量进行过滤。防火墙策略可以基于流量的源目地址、端口号、协议、应用等信息来定制，然后防火墙使用预先定制的策略规则监控出入的流量，若流量与某一条策略规则相匹配，则执行相应的处理，反之则丢弃。这样一来，就可以保证仅有合法的流量在企业内网和外部公网之间流动了。

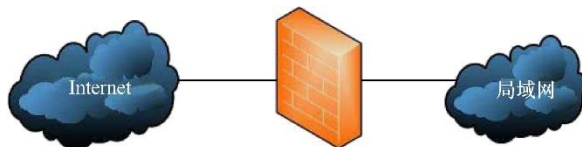


图 8-1 防火墙作为公网与内网之间的保护屏障

在 RHEL 7 系统中，firewalld 防火墙取代了 iptables 防火墙。对于接触 Linux 系统比较早

或学习过 RHEL 6 系统的读者来说, 当他们发现曾经掌握的知识在 RHEL 7 中不再适用, 需要全新学习 firewalld 时, 难免会有抵触心理。其实, iptables 与 firewalld 都不是真正的防火墙, 它们都只是用来定义防火墙策略的防火墙管理工具而已, 或者说, 它们只是一种服务。iptables 服务会把配置好的防火墙策略交由内核层面的 netfilter 网络过滤器来处理, 而 firewalld 服务则是把配置好的防火墙策略交由内核层面的 nftables 包过滤框架来处理。换句话说, 当前在 Linux 系统中其实存在多个防火墙管理工具, 旨在方便运维人员管理 Linux 系统中的防火墙策略, 我们只需要配置妥当其中的一个就足够了。虽然这些工具各有优劣, 但它们在防火墙策略的配置思路上是保持一致的。大家甚至可以不用完全掌握本章介绍的内容, 只要在这多个防火墙管理工具中任选一款并将其学透, 就足以满足日常的工作需求了。

8.2 iptables

在早期的 Linux 系统中, 默认使用的是 iptables 防火墙管理服务来配置防火墙。尽管新型的 firewalld 防火墙管理服务已经被投入使用多年, 但是大量的企业在生产环境中依然出于各种原因而继续使用 iptables。考虑到 iptables 在当前生产环境中还具有顽强的生命力, 以及为了使大家在求职面试过程中被问到 iptables 的相关知识时能胸有成竹, 刘遛老师觉得还是有必要在本书中好好地讲解一下这项技术。更何况前文也提到, 各个防火墙管理工具的配置思路是一致的, 在掌握了 iptables 后再学习其他防火墙管理工具时, 也有借鉴意义。

8.2.1 策略与规则链

防火墙会从上至下的顺序来读取配置的策略规则, 在找到匹配项后就立即结束匹配工作并去执行匹配项中定义的行为 (即放行或阻止)。如果在读取完所有的策略规则之后没有匹配项, 就去执行默认的策略。一般而言, 防火墙策略规则的设置有两种: 一种是“通”(即放行), 一种是“堵”(即阻止)。当防火墙的默认策略为拒绝时 (堵), 就要设置允许规则 (通), 否则谁都进不来; 如果防火墙的默认策略为允许时, 就要设置拒绝规则, 否则谁都能进来, 防火墙也就失去了防范的作用。

iptables 服务把用于处理或过滤流量的策略条目称之为规则, 多条规则可以组成一个规则链, 而规则链则依据数据包处理位置的不同进行分类, 具体如下:

- 在进行路由选择前处理数据包 (PREROUTING);
- 处理流入的数据包 (INPUT);
- 处理流出的数据包 (OUTPUT);
- 处理转发的数据包 (FORWARD);
- 在进行路由选择后处理数据包 (POSTROUTING)。

一般来说, 从内网向外网发送的流量一般都是可控且良性的, 因此我们使用最多的就是 INPUT 规则链, 该规则链可以增大黑客人员从外网入侵内网的难度。

比如在您居住的社区内, 物业管理公司有两条规定: 禁止小商小贩进入社区; 各种车辆在进入社区时都要登记。显而易见, 这两条规定应该是用于社区的正门的 (流量必须经过的地方), 而不是每家每户的防盗门上。根据前面提到的防火墙策略的匹配顺序, 可能会存在多种情况。比如, 来访人员是小商小贩, 则直接会被物业公司的保安拒之门外, 也就无需再对车

辆进行登记。如果来访人员乘坐一辆汽车进入社区正门，则“禁止小商小贩进入社区”的第一条规则就没有被匹配到，因此按照顺序匹配第二条策略，即需要对车辆进行登记。如果是社区居民要进入正门，则这两条规定都不会匹配到，因此会执行默认的放行策略。

但是，仅有策略规则还不能保证社区的安全，保安还应该知道采用什么样的动作来处理这些匹配的流量，比如“允许”、“拒绝”、“登记”、“不理它”。这些动作对应到 iptables 服务的术语中分别是 ACCEPT(允许流量通过)、REJECT(拒绝流量通过)、LOG(记录日志信息)、DROP(拒绝流量通过)。“允许流量通过”和“记录日志信息”都比较好理解，这里需要着重讲解的是 REJECT 和 DROP 的不同点。就 DROP 来说，它是直接将流量丢弃而且不响应；REJECT 则会在拒绝流量后再回复一条“您的信息已经收到，但是被扔掉了”信息，从而让流量发送方清晰地看到数据被拒绝的响应信息。

我们来举一个例子，让各位读者更直观地理解这两个拒绝动作的不同之处。比如有一天您正在家里看电视，突然听到有人敲门，您透过防盗门的猫眼一看是推销商品的，便会在不需要的情况下开门并拒绝他们（REJECT）。但如果您看到的是债主带了十几个小弟来讨债，此时不仅要拒绝开门，还要默不作声，伪装成自己不在家的样子（DROP）。

当把 Linux 系统中的防火墙策略设置为 REJECT 拒绝动作后，流量发送方会看到端口不可达的响应：

```
[root@linuxprobe ~]# ping -c 4 192.168.10.10
PING 192.168.10.10 (192.168.10.10) 56(84) bytes of data.
From 192.168.10.10 icmp_seq=1 Destination Port Unreachable
From 192.168.10.10 icmp_seq=2 Destination Port Unreachable
From 192.168.10.10 icmp_seq=3 Destination Port Unreachable
From 192.168.10.10 icmp_seq=4 Destination Port Unreachable
--- 192.168.10.10 ping statistics ---
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3002ms
```

而把 Linux 系统中的防火墙策略修改成 DROP 拒绝动作后，流量发送方会看到响应超时的提醒。但是流量发送方无法判断流量是被拒绝，还是接收方主机当前不在线：

```
[root@linuxprobe ~]# ping -c 4 192.168.10.10
PING 192.168.10.10 (192.168.10.10) 56(84) bytes of data.

--- 192.168.10.10 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3000ms
```

8.2.2 iptables 中基本的命令参数

iptables 是一款基于命令行的防火墙策略管理工具，具有大量参数，学习难度较大。好在对于日常的防火墙策略配置来讲，大家无需深入了解诸如“四表五链”的理论概念，只需要掌握常用的参数并做到灵活搭配即可，这就足以应对日常工作了。

iptables 命令可以根据流量的源地址、目的地址、传输协议、服务类型等信息进行匹配，一旦匹配成功，iptables 就会根据策略规则所预设的动作来处理这些流量。另外，再次提醒一下，防火墙策略规则的匹配顺序是从上至下的，因此要把较为严格、优先级较高的策略规则放到前面，以免发生错误。表 8-1 总结归纳了常用的 iptables 命令参数。再次强调，我们无需死记硬背这些参数，只需借助下面的实验来理解掌握即可。

表 8-1 iptables 中常用的参数以及作用

参数	作用
-P	设置默认策略
-F	清空规则链
-L	查看规则链
-A	在规则链的末尾加入新规则
-I num	在规则链的头部加入新规则
-D num	删除某一条规则
-s	匹配来源地址 IP/MASK，加叹号“!”表示除这个 IP 外
-d	匹配目标地址
-i 网卡名称	匹配从这块网卡流入的数据
-o 网卡名称	匹配从这块网卡流出的数据
-p	匹配协议，如 TCP、UDP、ICMP
--dport num	匹配目标端口号
--sport num	匹配来源端口号

在 iptables 命令后添加-L 参数查看已有的防火墙规则链：

```
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
ACCEPT all -- anywhere anywhere ctstate RELATED,ESTABLISHED
ACCEPT all -- anywhere anywhere
INPUT_direct all -- anywhere anywhere
INPUT_ZONES_SOURCE all -- anywhere anywhere
INPUT_ZONES all -- anywhere anywhere
ACCEPT icmp -- anywhere anywhere
REJECT all -- anywhere anywhere reject-with icmp-host-prohibited
.....省略部分输出信息.....
```

在 iptables 命令后添加-F 参数清空已有的防火墙规则链：

```
[root@linuxprobe ~]# iptables -F
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target    prot opt source                destination

Chain FORWARD (policy ACCEPT)
target    prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target    prot opt source                destination
.....省略部分输出信息.....
```

把 INPUT 规则链的默认策略设置为拒绝：

```
[root@linuxprobe ~]# iptables -P INPUT DROP
```

```
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy DROP)
target prot opt source destination
.....省略部分输出信息.....
```

前文提到，防火墙策略规则的设置有两种：通和堵。当把 INPUT 链设置为默认拒绝后，就要在防火墙策略中写入允许策略了，否则所有到来的流量都会被拒绝掉。另外，需要注意的是，规则链的默认拒绝动作只能是 DROP，而不能是 REJECT。

向 INPUT 链中添加允许 ICMP 流量进入的策略规则：

在日常运维工作中，经常会使用 ping 命令来检查对方主机是否在线，而向防火墙的 INPUT 规则链中添加一条允许 ICMP 流量进入的策略规则就默认允许了这种 ping 命令检测行为。

```
[root@linuxprobe ~]# iptables -I INPUT -p icmp -j ACCEPT
[root@linuxprobe ~]# ping -c 4 192.168.10.10
PING 192.168.10.10 (192.168.10.10) 56(84) bytes of data.
64 bytes from 192.168.10.10: icmp_seq=1 ttl=64 time=0.156 ms
64 bytes from 192.168.10.10: icmp_seq=2 ttl=64 time=0.117 ms
64 bytes from 192.168.10.10: icmp_seq=3 ttl=64 time=0.099 ms
64 bytes from 192.168.10.10: icmp_seq=4 ttl=64 time=0.090 ms
--- 192.168.10.10 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 2999ms
rtt min/avg/max/mdev = 0.090/0.115/0.156/0.027 ms
```

删除 INPUT 规则链中刚刚加入的那条策略（允许 ICMP 流量），并把默认策略设置为允许：

```
[root@linuxprobe ~]# iptables -D INPUT 1
[root@linuxprobe ~]# iptables -P INPUT ACCEPT
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
.....省略部分输出信息.....
```

将 INPUT 规则链设置为只允许指定网段的主机访问本机的 22 端口，拒绝来自其他所有主机的流量：

```
[root@linuxprobe ~]# iptables -I INPUT -s 192.168.10.0/24 -p tcp --dport 22 -j ACCEPT
[root@linuxprobe ~]# iptables -A INPUT -p tcp --dport 22 -j REJECT
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
ACCEPT tcp -- 192.168.10.0/24 anywhere tcp dpt:ssh
REJECT tcp -- anywhere anywhere tcp dpt:ssh reject-with icmp-port-unreachable
.....省略部分输出信息.....
```

再次重申，防火墙策略规则是按照从上到下的顺序匹配的，因此一定要把允许动作放到

拒绝动作前面，否则所有的流量就将被拒绝掉，从而导致任何主机都无法访问我们的服务。另外，这里提到的 22 号端口是 ssh 服务使用的（有关 ssh 服务，请见下一章），刘遛老师先在这里挖坑，等大家学完第 9 章后可再验证这个实验的效果。

在设置完上述 INPUT 规则链之后，我们使用 IP 地址在 192.168.10.0/24 网段内的主机访问服务器（即前面提到的设置了 INPUT 规则链的主机）的 22 端口，效果如下：

```
[root@Client A ~]# ssh 192.168.10.10
The authenticity of host '192.168.10.10 (192.168.10.10)' can't be established.
ECDSA key fingerprint is 70:3b:5d:37:96:7b:2e:a5:28:0d:7e:dc:47:6a:fe:5c.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.10.10' (ECDSA) to the list of known hosts.
root@192.168.10.10's password: 此处输入对方主机的 root 管理员密码
Last login: Sun Feb 12 01:50:25 2017
[root@Client A ~]#
```

然后，我们再使用 IP 地址在 192.168.20.0/24 网段内的主机访问服务器的 22 端口（虽网段不同，但已确认可以相互通信），效果如下，就会提示连接请求被拒绝了（Connection failed）：

```
[root@Client B ~]# ssh 192.168.10.10
Connecting to 192.168.10.10:22...
Could not connect to '192.168.10.10' (port 22): Connection failed.
```

向 INPUT 规则链中添加拒绝所有人访问本机 12345 端口的策略规则：

```
[root@linuxprobe ~]# iptables -I INPUT -p tcp --dport 12345 -j REJECT
[root@linuxprobe ~]# iptables -I INPUT -p udp --dport 12345 -j REJECT
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
REJECT udp -- anywhere anywhere udp dpt:italk reject-with icmp-port-unreachable
REJECT tcp -- anywhere anywhere tcp dpt:italk reject-with icmp-port-unreachable
ACCEPT tcp -- 192.168.10.0/24 anywhere tcp dpt:ssh
REJECT tcp -- anywhere anywhere tcp dpt:ssh reject-with icmp-port-unreachable
.....省略部分输出信息.....
```

向 INPUT 规则链中添加拒绝 192.168.10.5 主机访问本机 80 端口（Web 服务）的策略规则：

```
[root@linuxprobe ~]# iptables -I INPUT -p tcp -s 192.168.10.5 --dport 80 -j REJECT
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
REJECT tcp -- 192.168.10.5 anywhere tcp dpt:http reject-with icmp-port-unreachable
REJECT udp -- anywhere anywhere udp dpt:italk reject-with icmp-port-unreachable
REJECT tcp -- anywhere anywhere tcp dpt:italk reject-with icmp-port-unreachable
ACCEPT tcp -- 192.168.10.0/24 anywhere tcp dpt:ssh
REJECT tcp -- anywhere anywhere tcp dpt:ssh reject-with icmp-port-unreachable
.....省略部分输出信息.....
```

向 INPUT 规则链中添加拒绝所有主机访问本机 1000~1024 端口的策略规则：

```
[root@linuxprobe ~]# iptables -A INPUT -p tcp --dport 1000:1024 -j REJECT
[root@linuxprobe ~]# iptables -A INPUT -p udp --dport 1000:1024 -j REJECT
[root@linuxprobe ~]# iptables -L
Chain INPUT (policy ACCEPT)
target prot opt source destination
REJECT tcp -- 192.168.10.5 anywhere tcp dpt:http reject-with icmp-port-unreachable
REJECT udp -- anywhere anywhere udp dpt:italk reject-with icmp-port-unreachable
REJECT tcp -- anywhere anywhere tcp dpt:italk reject-with icmp-port-unreachable
ACCEPT tcp -- 192.168.10.0/24 anywhere tcp dpt:ssh
REJECT tcp -- anywhere anywhere tcp dpt:ssh reject-with icmp-port-unreachable
REJECT tcp -- anywhere anywhere tcp dpts:cadlock2:1024 reject-with icmp-port-unreachable
REJECT udp -- anywhere anywhere udp dpts:cadlock2:1024 reject-with icmp-port-unreachable
.....省略部分输出信息.....
```

有关 `iptables` 命令的知识讲解到此就结束了,大家是不是意犹未尽?考虑到 Linux 防火墙的发展趋势,大家只要能把上面的实例吸收消化,就可以完全搞定日常的 `iptables` 配置工作了。但是请特别注意,使用 `iptables` 命令配置的防火墙规则默认会在系统下一次重启时失效,如果想让配置的防火墙策略永久生效,还要执行保存命令:

```
[root@linuxprobe ~]# service iptables save
iptables: Saving firewall rules to /etc/sysconfig/iptables: [ OK ]
```

8.3 firewalld

RHEL 7 系统中集成了多款防火墙管理工具,其中 `firewalld` (Dynamic Firewall Manager of Linux systems, Linux 系统的动态防火墙管理器) 服务是默认的防火墙配置管理工具,它拥有基于 CLI (命令行界面) 和基于 GUI (图形用户界面) 的两种管理方式。

相较于传统的防火墙管理配置工具, `firewalld` 支持动态更新技术并加入了区域 (zone) 的概念。简单来说,区域就是 `firewalld` 预先准备了几套防火墙策略集合 (策略模板), 用户可以根据生产场景的不同而选择合适的策略集合,从而实现防火墙策略之间的快速切换。例如,我们有一台笔记本电脑,每天都要在办公室、咖啡厅和家里使用。按常理来讲,这三者的安全性按照由高到低的顺序来排列,应该是家庭、公司办公室、咖啡厅。当前,我们希望为这台笔记本电脑指定如下防火墙策略规则: 在家中允许访问所有服务; 在办公室内仅允许访问文件共享服务; 在咖啡厅仅允许上网浏览。在以往,我们需要频繁地手动设置防火墙策略规则,而现在只需要预设好区域集合,然后只需轻点鼠标就可以自动切换了,从而极大地提升了防火墙策略的应用效率。`firewalld` 中常见的区域名称 (默认为 `public`) 以及相应的策略规则如表 8-2 所示。

表 8-2 firewalld 中常用的区域名称及策略规则

区域	默认策略规则
trusted	允许所有的数据包
home	拒绝流入的流量,除非与流出的流量相关;而如果流量与 <code>ssh</code> 、 <code>mdns</code> 、 <code>ipp-client</code> 、 <code>amba-client</code> 与 <code>dhcpv6-client</code> 服务相关,则允许流量

internal	等同于 home 区域
work	拒绝流入的流量，除非与流出的流量数相关；而如果流量与 ssh、ipp-client 与 dhcpv6-client 服务相关，则允许流量
public	拒绝流入的流量，除非与流出的流量相关；而如果流量与 ssh、dhcpv6-client 服务相关，则允许流量
external	拒绝流入的流量，除非与流出的流量相关；而如果流量与 ssh 服务相关，则允许流量
dmz	拒绝流入的流量，除非与流出的流量相关；而如果流量与 ssh 服务相关，则允许流量
block	拒绝流入的流量，除非与流出的流量相关
drop	拒绝流入的流量，除非与流出的流量相关

8.3.1 终端管理工具

第 2 章在讲解 Linux 命令时曾经听到，命令行终端是一种极富效率的工作方式，firewall-cmd 是 firewalld 防火墙配置管理工具的 CLI（命令行界面）版本。它的参数一般都是以“长格式”来提供的，大家不要一听到长格式就头大，因为 RHEL 7 系统支持部分命令的参数补齐，其中就包含这条命令（很酷吧）。也就是说，现在除了能用 Tab 键自动补齐命令或文件名等内容之外，还可以用 Tab 键来补齐表 8-3 中所示的长格式参数了（这太棒了）。

表 8-3 firewall-cmd 命令中使用的参数以及作用

参数	作用
--get-default-zone	查询默认的区域名称
--set-default-zone=<区域名称>	设置默认的区域，使其永久生效
--get-zones	显示可用的区域
--get-services	显示预先定义的服务
--get-active-zones	显示当前正在使用的区域与网卡名称
--add-source=	将源自此 IP 或子网的流量导向指定的区域
--remove-source=	不再将源自此 IP 或子网的流量导向某个指定区域
--add-interface=<网卡名称>	将源自该网卡的所有流量都导向某个指定区域
--change-interface=<网卡名称>	将某个网卡与区域进行关联
--list-all	显示当前区域的网卡配置参数、资源、端口以及服务等信息
--list-all-zones	显示所有区域的网卡配置参数、资源、端口以及服务等信息
--add-service=<服务名>	设置默认区域允许该服务的流量
--add-port=<端口号/协议>	设置默认区域允许该端口的流量
--remove-service=<服务名>	设置默认区域不再允许该服务的流量
--remove-port=<端口号/协议>	设置默认区域不再允许该端口的流量
--reload	让“永久生效”的配置规则立即生效，并覆盖当前的配置规则
--panic-on	开启应急状况模式
--panic-off	关闭应急状况模式

与 Linux 系统中其他的防火墙策略配置工具一样，使用 firewalld 配置的防火墙策略默认为运行时（Runtime）模式，又称为当前生效模式，而且随着系统的重启会失效。如果想让配

置策略一直存在,就需要使用永久(Permanent)模式了,方法就是在用 firewall-cmd 命令正常设置防火墙策略时添加--permanent 参数,这样配置的防火墙策略就可以永久生效了。但是,永久生效模式有一个“不近人情”的特点,就是使用它设置的策略只有在系统重启之后才能自动生效。如果想让配置的策略立即生效,需要手动执行 firewall-cmd --reload 命令。

接下来的实验都很简单,但是提醒大家一定要仔细查看刘遑老师使用的是 Runtime 模式还是 Permanent 模式。如果不关注这个细节,就算是正确配置了防火墙策略,也可能无法达到预期的效果。

查看 firewalld 服务当前所使用的区域:

```
[root@linuxprobe ~]# firewall-cmd --get-default-zone
public
```

查询 eno16777728 网卡在 firewalld 服务中的区域:

```
[root@linuxprobe ~]# firewall-cmd --get-zone-of-interface=eno16777728
public
```

把 firewalld 服务中 eno16777728 网卡的默认区域修改为 external,并在系统重启后生效。分别查看当前与永久模式下的区域名称:

```
[root@linuxprobe ~]# firewall-cmd --permanent --zone=external --change-interface=
eno16777728
success
[root@linuxprobe ~]# firewall-cmd --get-zone-of-interface=eno16777728
public
[root@linuxprobe ~]# firewall-cmd --permanent --get-zone-of-interface=eno16777728
external
```

把 firewalld 服务的当前默认区域设置为 public:

```
[root@linuxprobe ~]# firewall-cmd --set-default-zone=public
success
[root@linuxprobe ~]# firewall-cmd --get-default-zone
public
```

启动/关闭 firewalld 防火墙服务的应急状况模式,阻断一切网络连接(当远程控制服务器时请慎用):

```
[root@linuxprobe ~]# firewall-cmd --panic-on
success
[root@linuxprobe ~]# firewall-cmd --panic-off
success
```

查询 public 区域是否允许请求 SSH 和 HTTPS 协议的流量:

```
[root@linuxprobe ~]# firewall-cmd --zone=public --query-service=ssh
yes
[root@linuxprobe ~]# firewall-cmd --zone=public --query-service=https
no
```

把 firewalld 服务中请求 HTTPS 协议的流量设置为永久允许,并立即生效:

```
[root@linuxprobe ~]# firewall-cmd --zone=public --add-service=https
```

```
success
[root@linuxprobe ~]# firewall-cmd --permanent --zone=public --add-service=https
success
[root@linuxprobe ~]# firewall-cmd --reload
success
```

把 firewalld 服务中请求 HTTP 协议的流量设置为永久拒绝，并立即生效：

```
[root@linuxprobe ~]# firewall-cmd --permanent --zone=public --remove-service=http
success
[root@linuxprobe ~]# firewall-cmd --reload
success
```

把在 firewalld 服务中访问 8080 和 8081 端口的流量策略设置为允许，但仅限当前生效：

```
[root@linuxprobe ~]# firewall-cmd --zone=public --add-port=8080-8081/tcp
success
[root@linuxprobe ~]# firewall-cmd --zone=public --list-ports
8080-8081/tcp
```

把原本访问本机 888 端口的流量转发到 22 端口，要且求当前和长期均有效：

注：

流量转发命令格式为 `firewall-cmd --permanent --zone=<区域> --add-forward-port=`
`<源端口号>:proto=<协议>:toport=<目标端口号>:toaddr=<目标 IP 地址>`

```
[root@linuxprobe ~]# firewall-cmd --permanent --zone=public --add-forward-port=
port=888:proto=tcp:toport=22:toaddr=192.168.10.10
success
[root@linuxprobe ~]# firewall-cmd --reload
success
```

在客户端使用 ssh 命令尝试访问 192.168.10.10 主机的 888 端口：

```
[root@client A ~]# ssh -p 888 192.168.10.10
The authenticity of host '[192.168.10.10]:888 ([192.168.10.10]:888)' can't
be established.
ECDSA key fingerprint is b8:25:88:89:5c:05:b6:dd:ef:76:63:ff:1a:54:02:1a.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '[192.168.10.10]:888' (ECDSA) to the list of known hosts.
root@192.168.10.10's password:此处输入远程 root 管理员的密码
Last login: Sun Jul 19 21:43:48 2017 from 192.168.10.10
```

firewalld 中的富规则表示更细致、更详细的防火墙策略配置，它可以针对系统服务、端口号、源地址和目标地址等诸多信息进行更有针对性的策略配置。它的优先级在所有的防火墙策略中也是最高的。比如，我们可以在 firewalld 服务中配置一条富规则，使其拒绝 192.168.10.0/24 网段的所有用户访问本机的 ssh 服务（22 端口）：

```
[root@linuxprobe ~]# firewall-cmd --permanent --zone=public --add-rich-rule="
rule family="ipv4" source address="192.168.10.0/24" service name="ssh" reject"
success
[root@linuxprobe ~]# firewall-cmd --reload
```

success

在客户端使用 ssh 命令尝试访问 192.168.10.10 主机的 ssh 服务（22 端口）:

```
[root@client A ~]# ssh 192.168.10.10
Connecting to 192.168.10.10:22...
Could not connect to '192.168.10.10' (port 22): Connection failed.
```

8.3.2 图形管理工具

在各种版本的 Linux 系统中，几乎没有能让刘遄老师欣慰并推荐的图形化工具，但是 firewall-config 做到了。它是 firewalld 防火墙配置管理工具的 GUI（图形用户界面）版本，几乎可以实现所有以命令行来执行的操作。毫不夸张的说，即使读者没有扎实的 Linux 命令基础，也完全可以通过它来妥善配置 RHEL 7 中的防火墙策略。firewall-config 的界面如图 8-2 所示，其功能具体如下。

- 1: 选择运行时（Runtime）模式或永久（Permanent）模式的配置。
- 2: 可选的策略集合区域列表。
- 3: 常用的系统服务列表。
- 4: 当前正在使用的区域。
- 5: 管理当前被选中区域中的服务。
- 6: 管理当前被选中区域中的端口。
- 7: 开启或关闭 SNAT（源地址转换协议）技术。
- 8: 设置端口转发策略。
- 9: 控制请求 icmp 服务的流量。
- 10: 管理防火墙的富规则。
- 11: 管理网卡设备。
- 12: 被选中区域的服务，若勾选了相应服务前面的复选框，则表示允许与之相关的流量。
- 13: firewall-config 工具的运行状态。

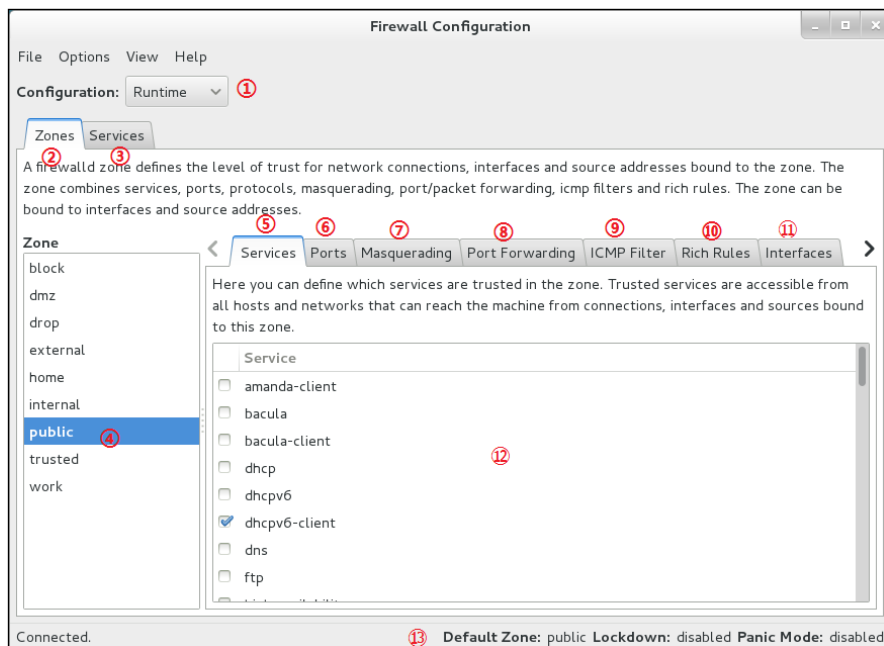


图 8-2 firewall-config 的界面

刘遄老师再啰嗦几句。在使用 `firewall-config` 工具配置完防火墙策略之后，无须进行二次确认，因为只要有修改内容，它就自动进行保存。下面进行动手实践环节。

我们先将当前区域中请求 `http` 服务的流量设置为允许，但仅限当前生效。具体配置如图 8-3 所示。

尝试添加一条防火墙策略规则，使其放行访问 8080~8088 端口（TCP 协议）的流量，并将其设置为永久生效，以达到系统重启后防火墙策略依然生效的目的。在按照图 8-4 所示的界面配置完毕之后，还需要在 `Options` 菜单中单击 `Reload Firewall` 命令，让配置的防火墙策略立即生效（见图 8-5）。这与在命令行中执行 `--reload` 参数的效果一样。

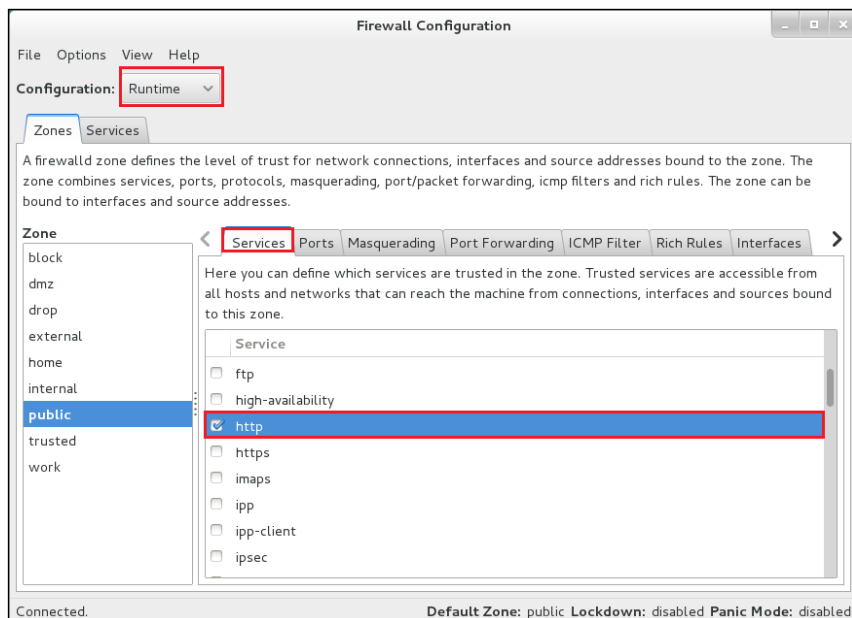


图 8-3 放行请求 http 服务的流量

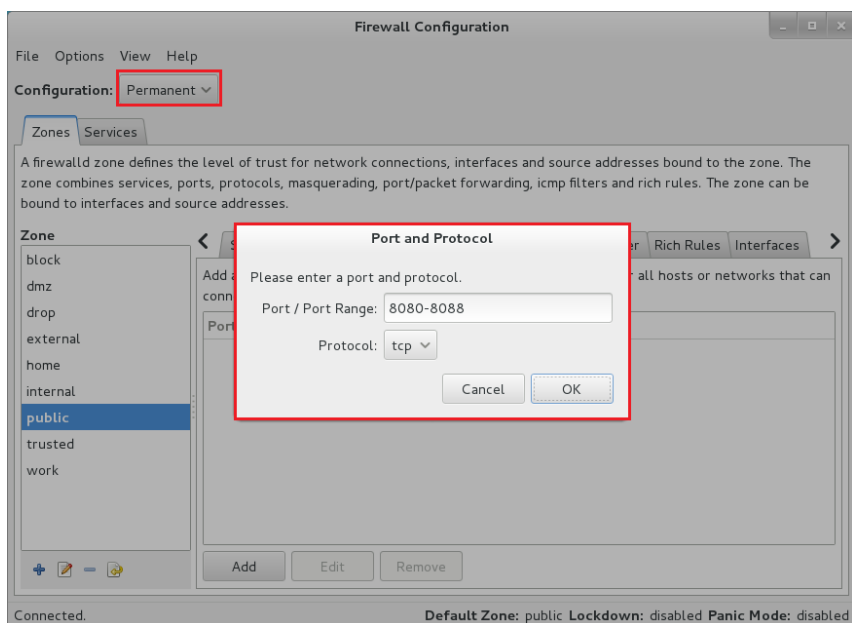


图 8-4 放行访问 8080~8088 端口的流量

前面在讲解 firewall-config 工具的功能时，曾经提到了 SNAT（Source Network Address Translation，源网络地址转换）技术。SNAT 是一种为了解决 IP 地址匮乏而设计的技术，它可以使得多个内网中的用户通过同一个外网 IP 接入 Internet。该技术的应用非常广泛，甚至可以说我们每天都在使用，只不过没有察觉到罢了。比如，当我们通过家中的网关设备（比如无线路由器）访问本书配套站点 www.linuxprobe.com 时，就用到了 SNAT 技术。

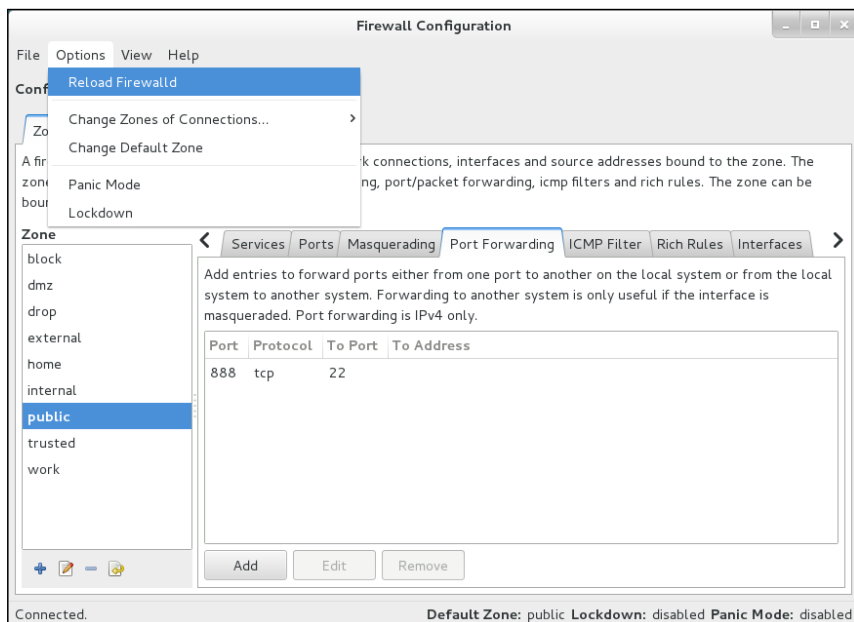


图 8-5 让配置的防火墙策略规则立即生效

大家可以看一下在网络中不使用 SNAT 技术（见图 8-6）和使用 SNAT 技术（见图 8-7）时的情况。在图 8-6 所示的局域网中有多台 PC，如果网关服务器没有应用 SNAT 技术，则互联网中的网站服务器在收到 PC 的请求数据包，并回送响应数据包时，将无法在网络中找到这个私有网络的 IP 地址，所以 PC 也就收不到响应数据包了。在图 8-7 所示的局域网中，由于网关服务器应用了 SNAT 技术，所以互联网中的网站服务器会将响应数据包发给网关服务器，再由后者转发给局域网中的 PC。

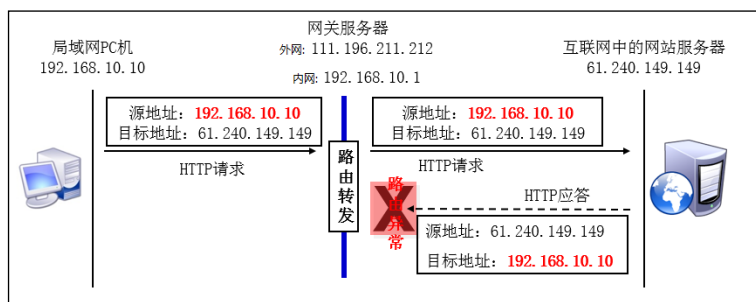


图 8-6 没有使用 SNAT 技术的网络

使用 iptables 命令实现 SNAT 技术是一件很麻烦的事情，但是在 firewall-config 中却是小菜一碟了。用户只需按照图 8-8 进行配置，并选中 Masquerade zone 复选框，就自动开启了 SNAT 技术。

为了让大家直观查看不同工具在实现相同功能的区别，这里使用 firewall-config 工具重新演示了前面使用 firewall-cmd 来配置防火墙策略规则，将本机 888 端口的流量转发到 22 端口，且要求当前和长期均有效，具体如图 8-9 和图 8-10 所示。

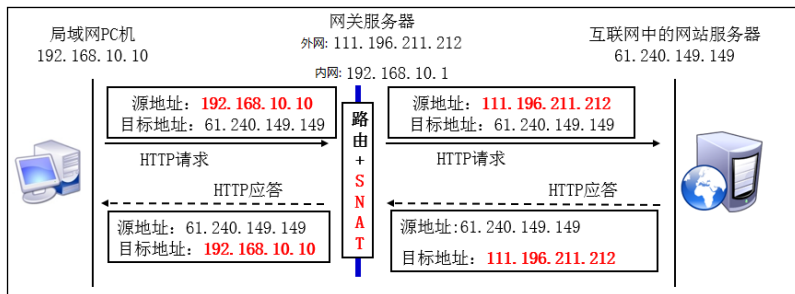


图 8-7 使用 SNAT 技术处理过的网络

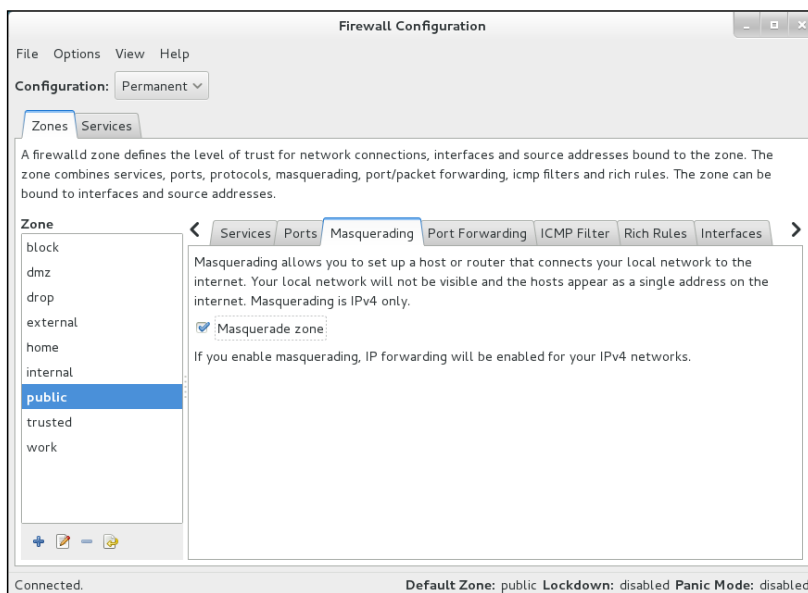


图 8-8 开启防火墙的 SNAT 技术

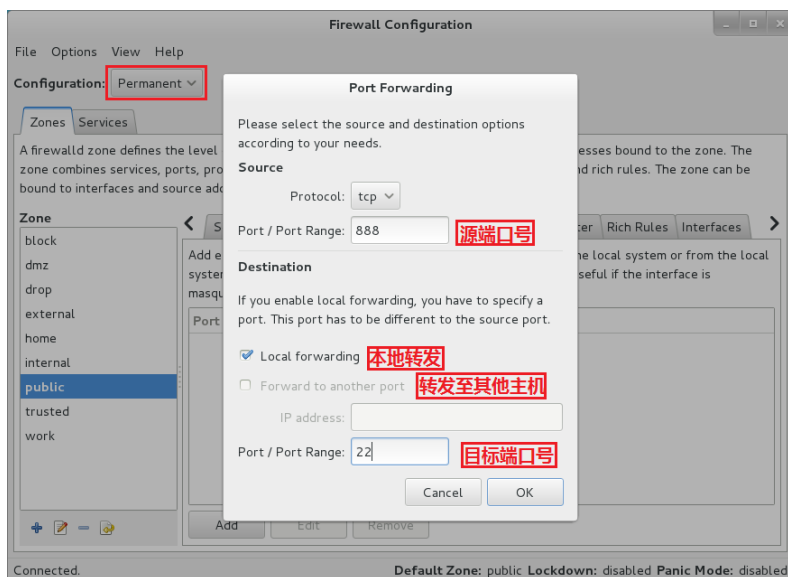


图 8-9 配置本地的端口转发

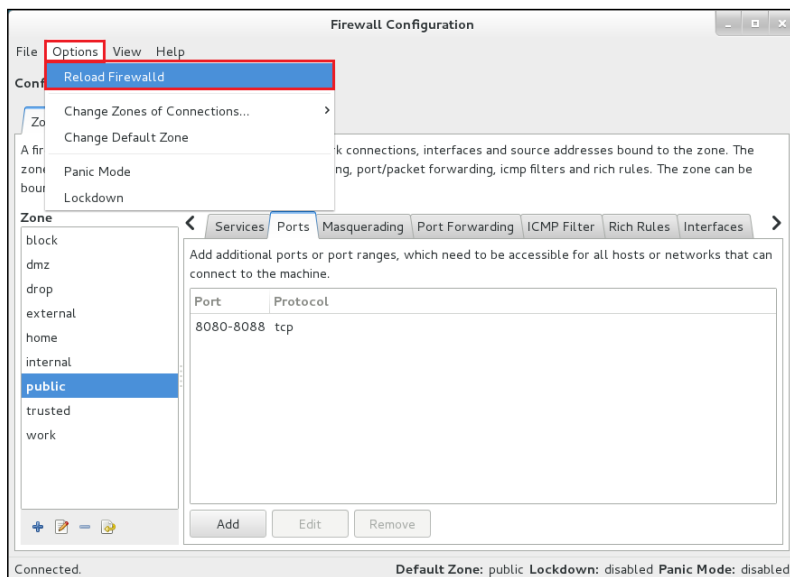


图 8-10 让防火墙策略规则立即生效

配置富规则，让 192.168.10.20 主机访问到本机的 1234 端口号，如图 8-11 所示。

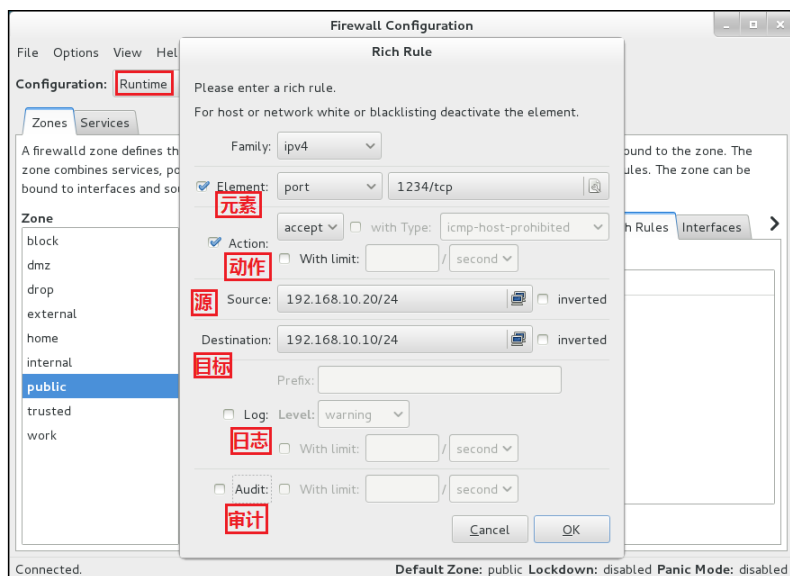


图 8-11 配置防火墙富规则策略

如果生产环境中的服务器有多块网卡在同时提供服务（这种情况很常见），则对内网和对外网提供服务的网卡要选择的防火墙策略区域也是不一样的。也就是说，可以把网卡与防火墙策略区域进行绑定（见图 8-12），这样就可以使用不同的防火墙区域策略，对源自不同网卡的流量进行针对性的监控，效果会更好。

最后，刘遛老师想说的是，firewall-config 工具真的非常实用，很多原本复杂的长命令被用图形化按钮替代，设置规则也简单明了，足以应对日常工作。所以再次向大家强调配置防火墙策略的原则——只要能够实现所需的功能，用什么工具请随君便。

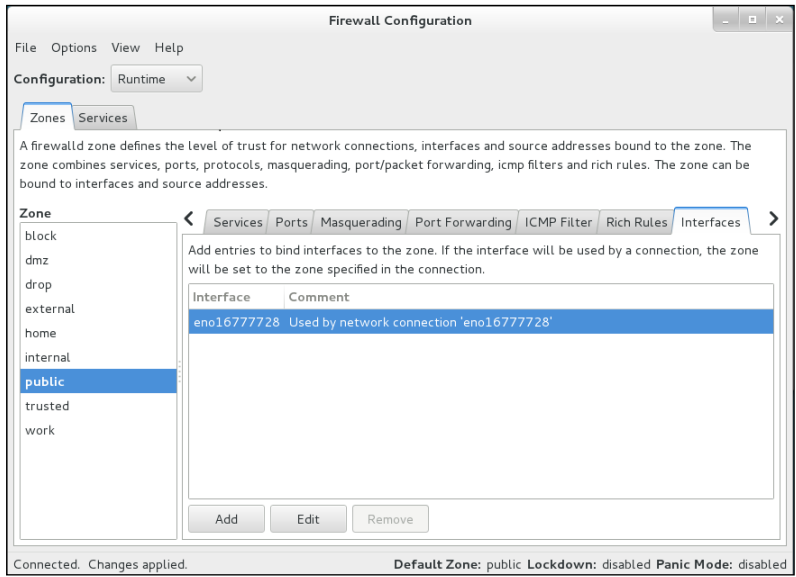


图 8-12 把网卡与防火墙策略区域进行绑定

8.4 服务的访问控制列表

TCP Wrappers 是 RHEL 7 系统中默认启用的一款流量监控程序，它能够根据来访主机的地址与本机的目标服务程序作出允许或拒绝的操作。换句话说，Linux 系统中其实有两个层面的防火墙，第一种是前面讲到的基于 TCP/IP 协议的流量过滤工具，而 TCP Wrappers 服务则是能允许或禁止 Linux 系统提供服务的防火墙，从而在更高层面保护了 Linux 系统的安全运行。

TCP Wrappers 服务的防火墙策略由两个控制列表文件所控制，用户可以编辑允许控制列表文件来放行对服务的请求流量，也可以编辑拒绝控制列表文件来阻止对服务的请求流量。控制列表文件修改后会立即生效，系统将会先检查允许控制列表文件（/etc/hosts.allow），如果匹配到相应的允许策略则放行流量；如果没有匹配，则去进一步匹配拒绝控制列表文件（/etc/hosts.deny），若找到匹配项则拒绝该流量。如果这两个文件全都没有匹配到，则默认放行流量。

TCP Wrappers 服务的控制列表文件配置起来并不复杂，常用的参数如表 8-4 所示。

表 8-4 TCP Wrappers 服务的控制列表文件中常用的参数

客户端类型	示例	满足示例的客户端列表
单一主机	192.168.10.10	IP 地址为 192.168.10.10 的主机
指定网段	192.168.10.	IP 段为 192.168.10.0/24 的主机
指定网段	192.168.10.0/255.255.255.0	IP 段为 192.168.10.0/24 的主机
指定 DNS 后缀	.linuxprobe.com	所有 DNS 后缀为 .linuxprobe.com 的主机
指定主机名称	www.linuxprobe.com	主机名称为 www.linuxprobe.com 的主机
指定所有客户端	ALL	所有主机全部包括在内

在配置 TCP Wrappers 服务时需要遵循两个原则：

- 编写拒绝策略规则时，填写的是服务名称，而非协议名称；

- 建议先编写拒绝策略规则，再编写允许策略规则，以便直观地看到相应的效果。

下面编写拒绝策略规则文件，禁止访问本机 sshd 服务的所有流量（无须/etc/hosts.deny 文件中修改原有的注释信息）：

```
[root@linuxprobe ~]# vim /etc/hosts.deny
#
# hosts.deny This file contains access rules which are used to
# deny connections to network services that either use
# the tcp_wrappers library or that have been
# started through a tcp_wrappers-enabled xinetd.
#
# The rules in this file can also be set up in
# /etc/hosts.allow with a 'deny' option instead.
#
# See 'man 5 hosts_options' and 'man 5 hosts_access'
# for information on rule syntax.
# See 'man tcpd' for information on tcp_wrappers
sshd:*

[root@linuxprobe ~]# ssh 192.168.10.10
ssh_exchange_identification: read: Connection reset by peer
```

接下来，在允许策略规则文件中添加一条规则，使其放行源自 192.168.10.0/24 网段，访问本机 sshd 服务的所有流量。可以看到，服务器立刻就放行了访问 sshd 服务的流量，效果非常直观：

```
[root@linuxprobe ~]# vim /etc/hosts.allow
#
# hosts.allow This file contains access rules which are used to
# allow or deny connections to network services that
# either use the tcp_wrappers library or that have been
# started through a tcp_wrappers-enabled xinetd.
#
# See 'man 5 hosts_options' and 'man 5 hosts_access'
# for information on rule syntax.
# See 'man tcpd' for information on tcp_wrappers
sshd:192.168.10.

[root@linuxprobe ~]# ssh 192.168.10.10
The authenticity of host '192.168.10.10 (192.168.10.10)' can't be established.
ECDSA key fingerprint is 70:3b:5d:37:96:7b:2e:a5:28:0d:7e:dc:47:6a:fe:5c.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.10.10' (ECDSA) to the list of known hosts.
root@192.168.10.10's password:
Last login: Wed May 4 07:56:29 2017
[root@linuxprobe ~]#
```

复习题

1. 在 RHEL 7 系统中，iptables 是否已经被 firewalld 服务彻底取代？

答：没有，iptables 和 firewalld 服务均可用于 RHEL 7 系统。

2. 请简述防火墙策略规则中 DROP 和 REJECT 的不同之处。

答：DROP 的动作是丢包，不响应；REJECT 是拒绝请求，同时向发送方回送拒绝信息。

3. 如何把 iptables 服务的 INPUT 规则链默认策略设置为 DROP？

答：执行命令 `iptables -P INPUT DROP` 即可。

4. 怎样编写一条防火墙策略规则，使得 iptables 服务可以禁止源自 192.168.10.0/24 网段的流量访问本机的 sshd 服务（22 端口）？

答：执行命令 `iptables -I INPUT -s 192.168.10.0/24 -p tcp --dport 22 -j REJECT` 即可。

5. 请简述 firewalld 中区域的作用。

答：可以依据不同的工作场景来调用不同的 firewalld 区域，实现大量防火墙策略规则的快速切换。

6. 如何在 firewalld 中把默认的区域设置为 dmz？

答：执行命令 `firewall-cmd --set-default-zone=dmz` 即可。

7. 如何让 firewalld 中以永久（Permanent）模式配置的防火墙策略规则立即生效？

答：执行命令 `firewall-cmd --reload`。

8. 使用 SNAT 技术的目的是什么？

答：SNAT 是一种为了解决 IP 地址匮乏而设计的技术，它可以使得多个内网中的用户通过同一个外网 IP 接入 Internet（互联网）。

9. TCP Wrappers 服务分别有允许策略配置文件和拒绝策略配置文件，请问匹配顺序是怎么样的？

答：TCP Wrappers 会先依次匹配允许策略配置文件，然后再依次匹配拒绝策略配置文件，如果都没有匹配到，则默认放行流量。